



UPI QR Code Security Specification

Version 1.0

February 2018

THIS PAGE IS INTENTIONALLY LEFT BLANK.

Copyright

UnionPay International Co. Ltd. ("UnionPay International") retains intellectual property rights concerning this specifications document and all other documents referenced, attached, and produced by UnionPay International, including but not limited to copyright, patents, trademarks, and trade secrets. Any use of this specifications document by any legal and/or natural person is limited by the rules specified in the agreement signed by UnionPay International Member Online Service (<http://member.unionpay.com/>) and UnionPay International. UnionPay International shall not be liable for any errors or omissions in this specifications document or any losses resulting therefrom.

Without UnionPay International's written consent, you may not use this specifications document for uses and purposes aside from matters involving cooperation with UnionPay International. Without UnionPay International's written consent, you may not download, forward, or, publically or in any other form, provide this specifications document to third parties. If any legal and/or natural person used illegal means to obtain this specifications document, please immediately delete it and notify UnionPay International.

UnionPay International makes no representations or warranties, including but not limited to, whether or not this specifications document or its related documents infringe upon the intellectual property rights of third parties. The user agrees that UnionPay International shall not be liable relating to whether or not the use of this specifications document infringes on third party rights.

© 2016 UnionPay International Co. Ltd. All rights reserved.

Trademarks

UnionPay International Co. Ltd. ("UnionPay International") and its various forms are registered trademarks of UnionPay International Co. Ltd. and its Affiliate(s). All other company or product names mentioned herein are trademarks of their respective companies.

© 2016 UnionPay International Co. Ltd. All rights reserved.

Table of Contents

ABOUT THIS DOCUMENT	III
1 QRC-BASED PAYMENT SYSTEM ARCHITECTURE.....	1
1.1 QRC-BASED PAYMENT TYPES	1
1.2 SYSTEM ARCHITECTURE.....	1
2 SECURITY OBJECTIVES	1
2.1 ENROLLING QRC BUSINESS SECURITY	2
2.2 QRC DATA SECURITY	2
2.3 ACCOUNT INFORMATION SECURITY	2
2.4 DATA TRANSMISSION SECURITY	2
2.5 PAYMENT PROCESSING SECURITY	2
3 SECURITY IMPLEMENTATION REQUIREMENTS.....	2
3.1 QRC DATA GENERATION/DECODING SECURITY REQUIREMENTS	2
3.2 DATA TRANSMISSION SECURITY REQUIREMENTS	3
3.3 USER AUTHENTICATION REQUIREMENTS	3
3.4 APPLICATION SOFTWARE SECURITY REQUIREMENTS	3
3.5 QRC SCANNING/DISPLAYING DEVICE SECURITY REQUIREMENTS.....	4
3.6 SECURITY REQUIREMENTS OF QR CODE BASED PAYMENT SYSTEM	5
3.7 OTHER SECURITY REQUIREMENTS.....	5

List of Figures

Figure 1 QRC-based payment system architecture.....	1
---	---

About this Document

Purpose

This document specifies the QR code (QRC) security requirements of devices, applications and systems, which include QRC scanning device, displaying device, application software, and processing system, etc.

This Technical Specification applies to devices, applications and systems which are involved in payment-oriented or collection-oriented QRC transactions. For other QRC applications, including but not limited to tickets, coupons, transaction documents, institution identification codes, product identification codes, anti-counterfeiting labels, the security requirements can refer to the corresponding chapters in this Specification according to the practical application security needs, but the details are out the scope of this Specification.

Audience

This document is intended for terminal device manufacturers, application software developers and acquirers.

Document Version

The December 2016 version is the first released version.

Revisions

UPI will periodically issue revisions to this document as enhancements and changes are implemented, or as corrections are required. Revisions or additions to this document will be published in an Operations Bulletin.

Time Expressed

UPI has operation centers in several locations, including Shanghai and Beijing. For operational purpose, the time frame in this document, unless particularly indicated, refers to "Beijing time". Coordinated Universal Time (UTC) is the global standard time by which the world follows. Beijing time is 8 hours ahead of UTC. There is no Daylight Saving Time in China.

Unless otherwise specified; the day mentioned in this document refers to the calendar day. The business day refers to the working day subject to local regulations of the country where the processing Member is located.

References

The terms and conditions in this document have quoted the following publications. Any later versions of these publications will not be applied in this document unless specified.

- ISO/IEC 15423-2009 Information technology - Automatic identification and data capture techniques - Bar code scanner and decoder performance testing.
- ISO/IEC 18004-2006 Information technology - Automatic identification and data capture techniques - QR Code 2005 bar code symbology specification.
- ISO 8601-2000 Data elements and interchange formats; information interchange; representation of dates and times.

- PCAC/T 0001-2016 Technical guideline of personal information protection
- PCAC 0002-2016 Technical guideline of barcode payment security
- UnionPay Payment Tokenization Implementation Guide.

Support

Please address your questions to the following service team:

[Technical Specifications Team]

[E-mail: ts@unionpayintl.com]

Terms and Definitions

Terms	Definition
QR Code (QRC)	Quick Response Code, a graphical image that records data information.
Application software	An application software installed in the QRC reading device and/or displaying device (such as smart phones or other devices), which is capable to read/display QRC, encode/decode QRC, as well as transmit the cardholder authorization or settlement data securely.
Point of sale(POS)	The terminal to accept UnionPay cards, which can securely obtain and protect account information, verification information and transaction message. POS must be able to store certificates and keys in a secure way, authenticate and establish a secure channel with back-end system, read and encrypt bank card information (including magnetic strip card and IC card), accept user input and encrypt personal identification number (PIN, display transaction type, amount, result and other transaction information, encrypt account information, as well as calculate message authentication code (MAC).
QRC Scanning device	A kind of device for capture and decode QRC images, including but not limited to smart mobile terminal, point-of-sales terminal(POS). The scanning device can be integrated with or connected to other devices. It must be able to prevent from information leakage and tampering.
Personal identification number: PIN	A number used to verify the cardholder's legitimate identity in transaction, which must not be present in plain text in any stage during the transaction.
Account information	Account information includes all information recorded in the bank card and relevant user ID verification information for bank card transaction. The information recorded on bank card includes: Primary account number (PAN), cardholder's name, magnetic track information, expiry date, card verification number (CVN and CVN2). Relevant user ID verification information for bank card transaction includes: personal identification number (PIN), user name, real name, ID number and contact info used in online banking, phone banking transactions and mobile banking.
QRC processing system	A centralized management platform for QRC-based e-payment, which is able to encode and decode the QRC (including QRC validity management), transaction processing, terminal/client APP management, authority authentication, key management, identification authentication, etc.

Word Convention

Convention	Tone	Implication
Shall	Mandatory	Must be followed without exception

Should	Optional but recommended	Required to follow but optional
Must	Mandatory	Required without exception
Must not	Mandatory	Not required
Could	Optional	Hypothetical
Can	Optional	Stating a capability
Cannot	Optional	Stating an incapability
May	Optional	Stating a possibility

Style Convention

Convention	Description
boldface	Note/emphasis
<i>italic</i>	Publications/book titles

1 QRC-based Payment System Architecture

1.1 QRC-based Payment Types

QRC-based payment can be classified to merchant presented QRC and consumer presented QRC. The merchant presented QRC refers to that merchant generates a collection QRC and the cardholder use mobile device to scan the QRC and complete the payment. In this specification, information contained in merchant presented QRC includes order information, etc.; The consumer presented QRC refers to that cashier or clerk of the merchant uses QRC scanning device to read QRC presented on user's smart phone or other smart terminal and completes payment transaction. In this specification, information contained in a consumer presented QRC includes bank card or other account information, etc..

1.2 System Architecture

The QRC-based payment system architecture described in this specification is shown as Figure 1.

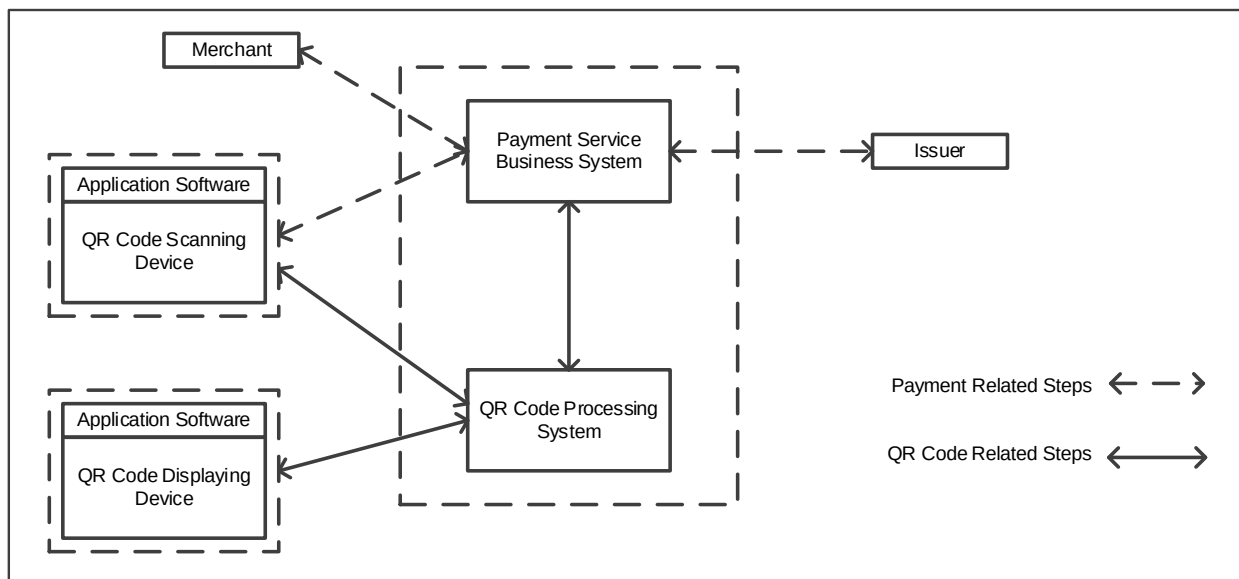


Figure 1 QRC-based payment system architecture

- Application software: refer to Terms and Definitions.
- QRC scanning device: refer to Terms and Definitions.
- QRC displaying device: a device which can display QRC accurately and securely.
- QRC processing system: refer to Terms and Definitions.
- Payment service business system: the transaction processing platform actually completes a QRC-based payment that achieves corresponding business processing logic.

2 Security Objectives

The security objective is to guarantee the information safety of personal, merchant and institution as well as payment transaction through enrolling the QRC business securely, protecting the QRC data from being compromised or tampered, transmitting information securely and processing payment transaction securely.

2.1 Enrolling QRC Business Security

The user account and personal information must not be disclosed during enrollment of the QRC business,.

2.2 QRC Data Security

- Ensure that the QRC contained account information must be anti-replaying;
- Ensure that account information is not disclosed;
- Authenticate the integrity, authenticity, non-repudiation and timeliness of QRC information during data parsing. Block the illegal QRCs that are not authenticated.

2.3 Account Information Security

- Shall not store account information in any device or system;
- Account information must not be used for any purpose other than completing existing valid transactions. Payment tokenization technology shall be applied to mask the sensitive information such as bank card number, card verification number and payment account, etc. Technology methods should be used to control source information leakage and fraudulent trading risks;
- The protection of account information shall comply with PCAC/T 0001: 2016. The scope of sensitive information in the QRC payment transaction should be defined according to business scope, security management requirements and customer service requirements. High sensitive information shall include static password and dynamic password, etc.; intermediate sensitive information shall include bank card number, ID number, passport number and mobile phone number, etc.; low sensitive information shall include name, address, e-mail address and transaction information etc.; the collection, display, storage, transmission and usage of information shall comply with requirements of PCAC/T 0001: 2016.

2.4 Data Transmission Security

QRC information shall not be transmitted in plain text in public network, and shall not be disclosed, compromised or tampered during transmission.

2.5 Payment Processing Security

The device and system involved in QRC payment should ensure the payment process security, including but not limited to authenticity and non-repudiation.

3 Security Implementation Requirements

3.1 QRC Data Generation/Decoding Security Requirements

- The QRC used in payment shall contain information that can be used to verify the authenticity of QRC source. The mechanisms that can be used include but not limited to digital signature and valid source whitelist, etc. During the decoding process, the source and authenticity of QRC shall be verified to ensure that no hazardous information, such as Trojan horse, virus or malicious link, is contained. When an unauthenticated QRC is detected, the transaction shall be rejected after an explicit warning message;
- The account information contained in QRC shall be processed with Token technology.
- The account information contained in QRC shall be anti-replaying. The mechanisms that can be used include but not limited to timeliness and dynamic generation, etc.;
- The QRC decoding process shall authenticate the validity, legitimacy and authenticity of QRC information, and ensure that the account information or user privacy information (e.g. ID information) is not leaked or stored in plain text.

3.2 Data Transmission Security Requirements

In case of transmitting account information in a vulnerable network environment, data encryption process shall be applied. The following requirements (but not limited to) shall be complied with:

- Robust encryption algorithm and security protocol, such as transport layer security (TLS 1.00 or above) and IP security protocol (IPSEC), shall be applied to protect data transmission on open/public network (e.g. Internet, GSM, 3G/4G wireless communication network).

3.3 User Authentication Requirements

- The user of QRC payment service shall have a unique personal identification, to ensure that the operation of QRC payment can be traced back to the user;
- User identification and authentication shall conform to UnionPay Identification and Authentication Standard;
- PIN input device security level shall conform to UnionPay Security Specification for Terminal Accepting UnionPay Card Part 6: Security Specification On PIN Entry Device Accepting UnionPay Card;
- The use of the initial password shall be rigorously restricted. The complexity of password should be verified. Simple passwords or passwords which are similar to user personal information should be avoided.

3.4 Application Software Security Requirements

- Security requirements of QRC generation/decoding refer to section 3.1;
- Security requirements for data transmission between application software and back-end system refer to section 3.2;
- The software shall able to scan malicious code (start Trojan or malicious website redirection, etc.) and to prevent the redirection or the start of malicious software;
- Software application shall upgrade security prevention and control ability through Trojan and virus prevention, information encryption protection, running environment reliability and other aspects;
- The application software module which implements the payment process shall conform to PCI PA-DSS requirements;
- QRC payment-related certificates shall be stored and maintained in accordance with PCI DSS requirements;

- QRC payment instruction authentication shall comply with PCI DSS requirements;
- During transaction, a security notification mechanism shall be provided, to ensure mandatory notification of key steps of the transaction (e.g. transaction amount and type confirmation, password input, etc.). Also the transaction result shall be present to consumer in a secure and effective way. The transaction can progress to the next step only if the consumer confirms.
- The application software programs shall have anti-reversion analysis, anti-disassemble and other security countermeasures to prevent attackers from debugging, analyzing or tampering the client program;
- The application software program shall not store account information in its temporary files, including but not limited to cookies;
- The application software program shall not store account information in plain text after identity authentication, as to avoid disclosure of sensitive information;
- Software application shall run in a reliable running environment;
- Software application can detect mobile payment security condition and send the feedback to the back-end system which can be used as basis for risk control strategy;
- Application software shall be evaluated through external compliance program.

3.5 QRC Scanning/Displaying Device Security Requirements

- QRC generation/decoding security requirements refer to section 3.1;
- Security requirements for data transmission between QRC scanning/displaying device and back-office system refer to section 3.2;
- Security requirements for firmware and application of QRC scanning and displaying devices refer to section 3.4;
- The specialized QRC scanning device security requirements shall meet UnionPay Specification for Terminal Accepting UnionPay Card Part1 Point of Sale terminal;
- The QRC scanning device and system shall be capable to anti-replaying to prevent enciphered data and transaction message from replaying;
- The firmware and application program of QRC scanning device shall be signed by acquirer or its authorized manufacturer/maintenance company. The device should verify the signature authentication of the downloaded program;
- The acceptance terminal shall be assigned a unique identification number so that the acceptance terminal device involved in the transaction can be traced back. The transaction message shall contain the acceptance terminal identification number. Technical encryption measures and management measures shall be adopted to prevent the acceptance terminal identification number from tampering in the transaction lifecycle;
- Institutions shall implement the corresponding terminal verification platform which shall be able to verify the validity of the terminal by the terminal identification number;
- In the use case of merchant presented QRC mode, when merchant presented QRC cannot be real-time encrypted or retrieved from back-end server, acquirer shall ensure the static QRC have counterfeit functions with unique identification information (e.g. Institution number, merchant number, etc.) and technical measures like signature which ensure the validity of information should be adopted. Acquirer institution shall undertake corresponding security risks, enforce the risk warnings to merchants and perform check periodically.

3.6 Security Requirements of QR Code Based Payment System

- QRC generation/decoding security requirements refer to section 3.1;
- Security requirements for system transmission refer to section 3.2;
- The system shall comply with PCI DSS requirements
- The system's information system security level shall be Level 3 and above;
- System shall not store any sensitive payment information;
- System shall make use of encryption technology to ensure the transmission and usage security of sensitive information;
- User login credentials shall be stored in secured manner (encrypted) to protect it from cracking or replaying.

3.7 Other Security Requirements

- The client application distributors shall be able to identify the application provided by themselves;
- Institutions who contracts with special merchants shall be able to identify their special merchants' acceptance devices. The information forwarded should contain the type and code of the acceptance devices (online payment interface).
- Perform regular internal security audit for sensitive information.